

Netzwerkforensik (Mitglied 1)

Asservat

Datei	silent_quarry.pcap
Größe	8.82 MB
Gesamtpakete	12.132
Aufnahmeort	VM2 (Server), Interface ens37
Aufnahmedauer	00:05:36
SHA256	be90bf4ef239aead9675acb509d2262d30b540142db01d9e91e56d1f578871d4

Identifiziertes Netzwerkumfeld

IP-Adresse	Rolle	MAC	OS-Indikator
192.168.50.10	Angreifer (Kali)	00:0C:29:41:13:85	Linux (TTL 64)
192.168.50.20	Server (Opfer)	00:0C:29:23:90:01	Linux (TTL 64), SSH Port 22 offen
192.168.50.30	Client (Opfer)	00:0C:29:CF:1A:0D	Windows (TTL 128), RDP Port 3389 offen, Hostname: DESKTOP-GKDAU52

Rekonstruierte Angriffs-Timeline

Zeit (UTC)	Zeit (CEST)	Ereignis	Beweis
00:23:42	02:23:42	RDP-Verbindung aufgebaut	Sessions-Tab, Port 3389
00:23:42	02:23:42	Benutzername "vogel" erfasst	RDP-Cookie (Credentials-Tab)
00:24:35	02:24:35	SSH-Verbindung #1(Exfiltration)	Sessions-Tab, Port 22
00:26:47	02:26:47	SSH-Verbindung #2	Sessions-Tab, Port 22

Zentrale Befunde

Zusammenfassung der zentralen Befunde

ID	Vektor / Thema	Betroffene Systeme	Kernbefund / Evidenz
B001-NETZ-SQ-2026	RDP-Angriffsvektor	192.168.50.10 (Angreifer) -> 192.168.50.30 (Client)	TLS-1.2-verschlüsselte RDP-Sitzung. Übertragung von ca. 8 MB Bildschirmdaten. Benutzername "vogel" wurde im RDP-Cookie im Klartext erfasst.
B002-NETZ-SQ-2026	SSH-Credential-Wiederverwendung	192.168.50.10 (Angreifer)	Aufbau von zwei SSH-Sitzungen mit den gestohlenen

			-> 192.168.50.20 (Server)	Zugangsdaten von “vogel”. Erste Sitzung dauerte 233s, zweite Sitzung war eine kurze Zweitverbindung (6s) ohne Datenextraktion.
B003-NETZ- SQ-2026	Datenexfiltration		192.168.50.20 (Server) -> 192.168.50.10 (Angreifer)	Exfiltration von ca. 1 MB verschlüsselten Daten innerhalb der ersten SSH-Sitzung. Kontinuierlicher Transfer über ca. 4 Minuten hinweg.
B004-NETZ- SQ-2026	TLS-Zertifikat		192.168.50.30 (Client)	Extraktion des Zertifikats DESKTOP- GKDAU52.cer aus dem RDP- Handshake. Bestätigt unabhängig den Windows- Hostnamen des Opfer-Clients.

Finding 1: RDP als Angriffsvektor

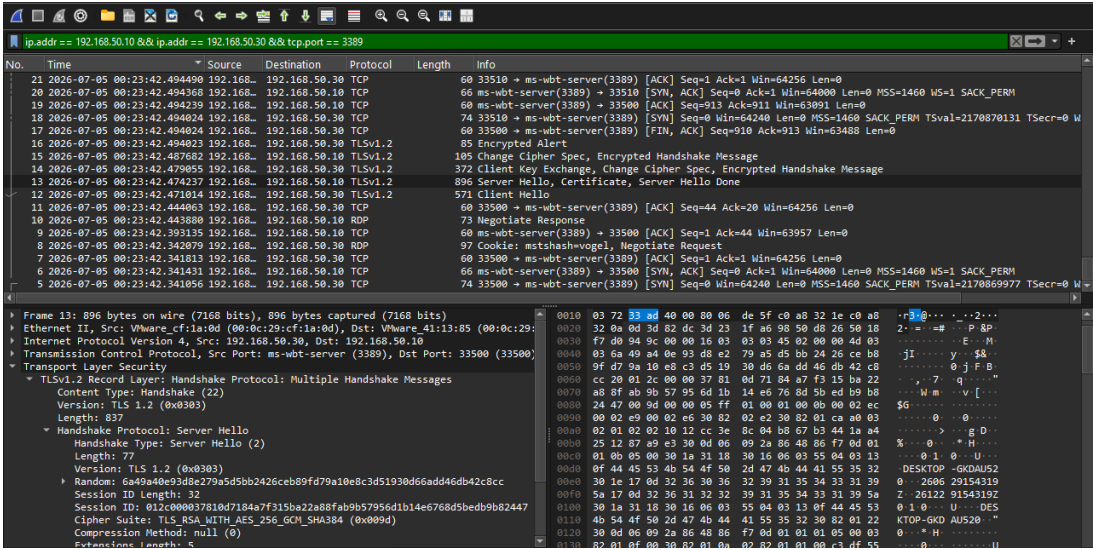


Figure 1: Ausgabe von RDP in Wireshark durch Port 3389

- Der Angreifer (192.168.50.10) verband sich per RDP (Port 3389) mit dem Client.
- Die Verbindung war TLS-1.2-verschlüsselt.

- Es wurden ca. 8 MB Bildschirmdaten vom Client zum Angreifer übertragen.

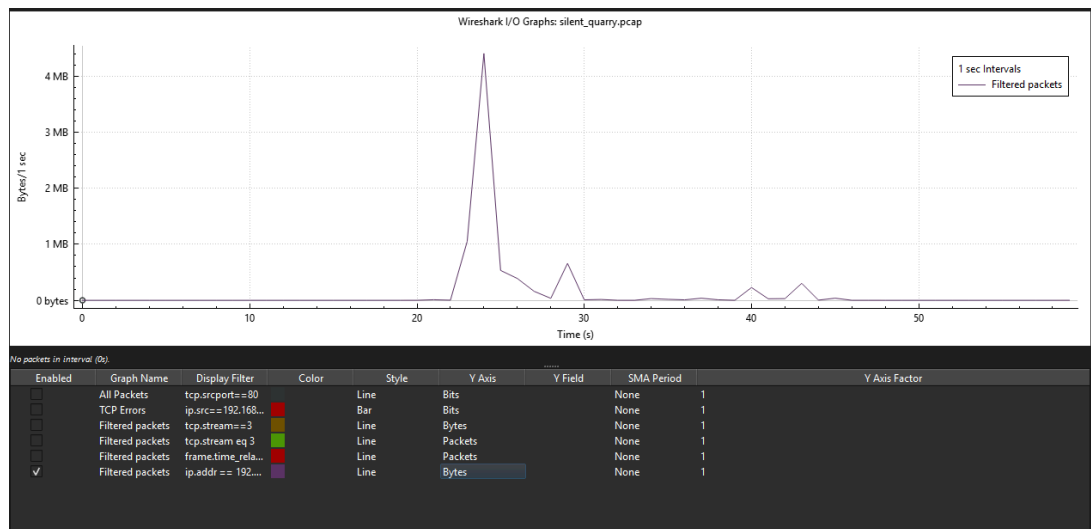


Figure 2: Ausgabe von Graph zeigt 8MB transferiert werden als RDP

- Der Benutzername “vogel” wurde im RDP-Cookie im Klartext erfasst und belegt den Diebstahl der Zugangsdaten.

Finding 2: SSH-Zugangsdatenwiederverwendung

Der Angreifer nutzte die gestohlenen Zugangsdaten (m.vogel) in Desktop von vogel, um sich per SSH am Server anzumelden. Es wurden zwei SSH-Sitzungen aufgebaut:

Hosts (6) Files (2) Images Messages Credentials (1) Sessions (4) DNS Parameters (40) Keywords						
Enter a keyword filter						
☐	Case sensitive	Exact Phrase	Start time	Clear	Apply	
Frame nr.	Client host	C. port	Server host	S. port	Protocol (application layer)	Start time
5	192.168.50.10	33500	192.168.50.30	3389	TPKT	2026-07-05 00:23:42 UTC+00
18	192.168.50.10	33510	192.168.50.30	3389	TPKT	2026-07-05 00:23:42 UTC+00
1938	192.168.50.10	47922	192.168.50.20	22	SSH	2026-07-05 00:24:35 UTC+00
5077	192.168.50.10	52306	192.168.50.20	22	SSH	2026-07-05 00:26:47 UTC+00

Figure 3: Ausgabe von Proof für 2 SSH Verbindungen

1. **Erste Sitzung:** OpenSSH 10.2p1 (Kali) → OpenSSH 9.6p1 (Ubuntu Server), 2026-07-05 00:24:35 UTC, Dauer 233 Sekunden

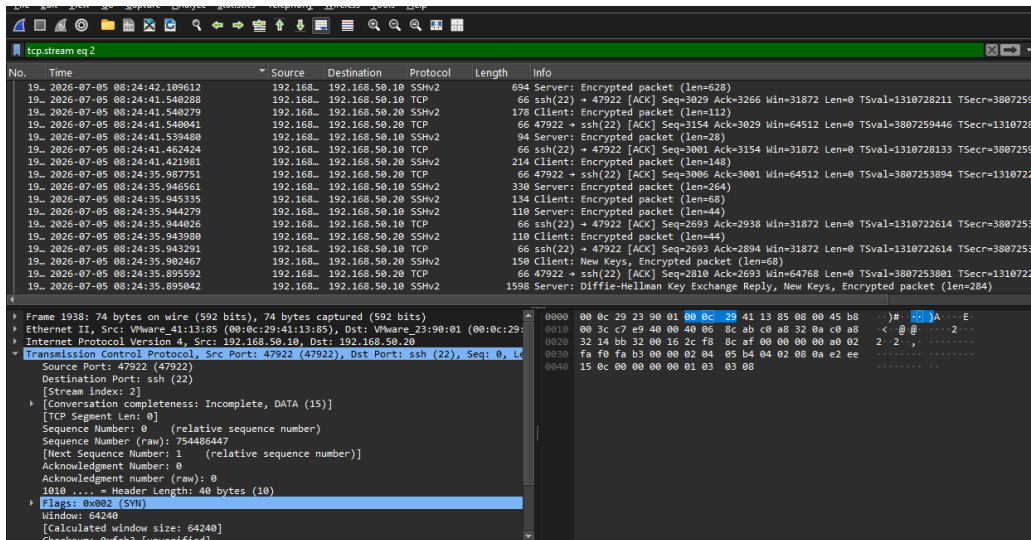


Figure 4: Ausgabe von Erste SSH Verbindung

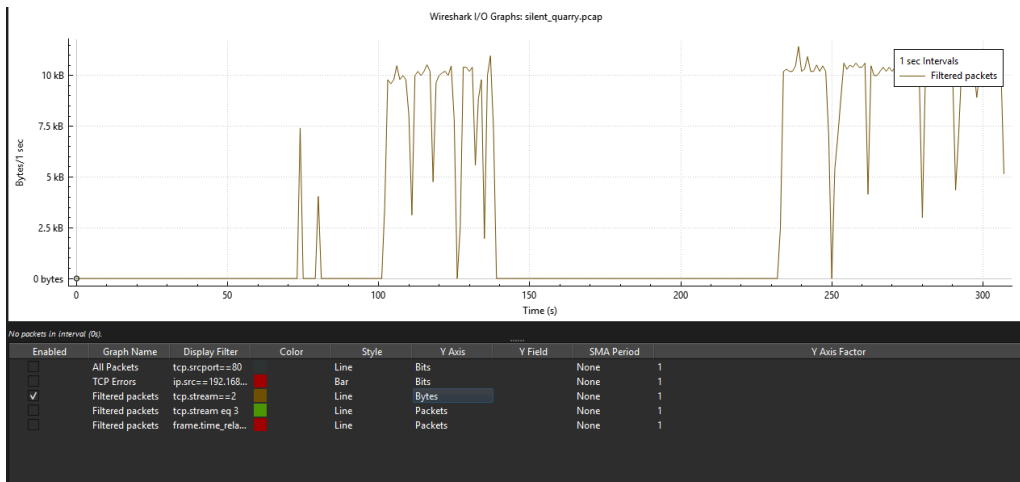


Figure 5: Ausgabe von Erste SSH Verbindung Graph

2. **Zweite Sitzung:** geringes Datenvolumen, 2026-07-05 00:26:47 UTC, Dauer 6 Sekunden
(Einschätzung: Hier liegt keine Extraktion vor, sondern lediglich eine kurze Zweitverbindung.)

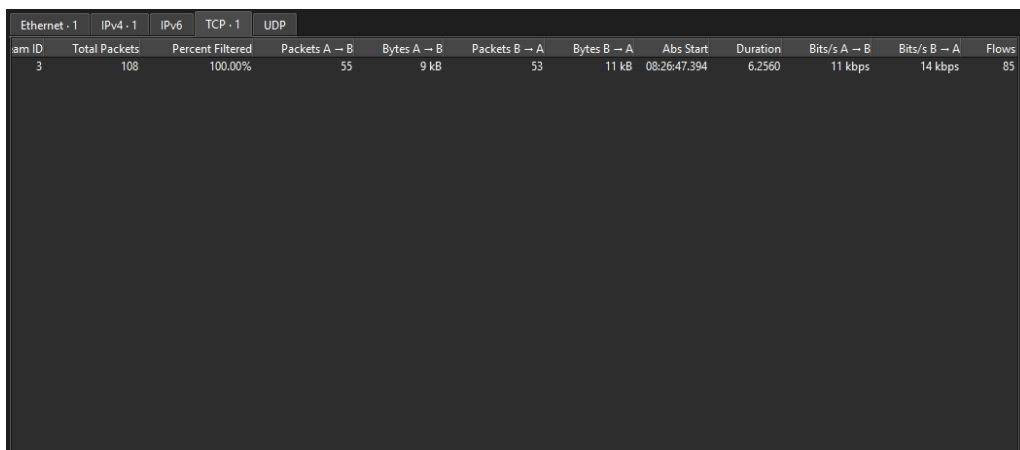


Figure 6: Ausgabe von Zweite SSH Verbindung

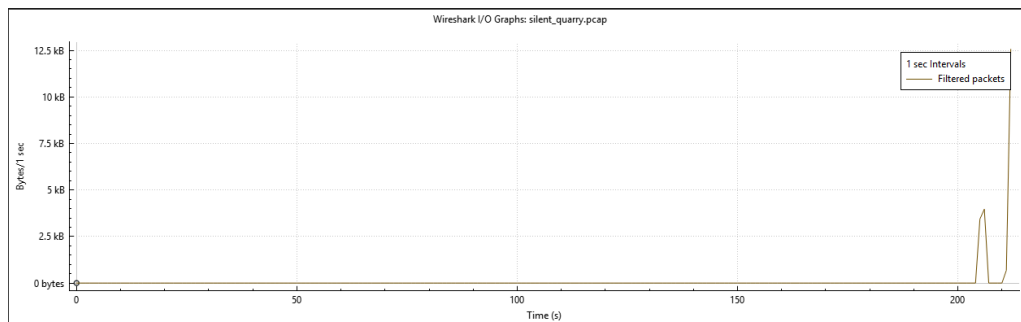


Figure 7: Ausgabe von Zweite SSH Graph

Finding 3: Datenexfiltration

Innerhalb der ersten SSH-Sitzung (OpenSSH 10.2p1 → OpenSSH 9.6p1, 2026-07-05 00:24:35 UTC, 233 Sekunden):

- ca. 1 MB wurde vom Server zum Angreifer übertragen

Ethernet · 1	IPv4 · 1	IPv6	TCP · 1	UDP							
Bytes	Stream ID	Total Packets	Percent Filtered	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Abs Start	Duration	Bits/s A → B	Bits/s B → A
1 MB	2	10,082	100.00%	5,049	517 kB	5,033	521 kB	08:24:35.867	233.0608	17 kbps	17 kbps

Figure 8: Ausgabe von Wireshark über 1MB Daten transferiert werden

- kontinuierlicher Transfer über ca. 4 Minuten
- der Dateninhalt selbst ist SSH-verschlüsselt, Volumen und Richtung belegen jedoch den Diebstahl

Finding 4: Extrahiertes TLS-Zertifikat

Aus dem RDP-TLS-Handshake wurde das Zertifikat DESKTOP-GKDAU52.cer extrahiert.

Frame nr.	Filename	Extension	Size	Source host	S. port	Destination host	D. port	Protocol	Timestamp	Reconstructed file path
13	DESKTOP-GKDAU52.cer	cer	742 B	192.168.50.30	TCP 3389	192.168.50.10	TCP 33500	TlsCertificate	2026-07-05 00:23:42 UTC+00	C:\Users\User\AppData\Local\Netw...
27	DESKTOP-GKDAU52(1).cer	cer	742 B	192.168.50.30	TCP 3389	192.168.50.10	TCP 33510	TlsCertificate	2026-07-05 00:23:42 UTC+00	C:\Users\User\AppData\Local\Netw...

Filename	MD5
silent_qu...	a51821...

Figure 9: Ausgabe von Zertifikat von Opfer

Es bestätigt den Windows-Hostnamen des Opfer-Clients.

Bestätigung der isolierten Umgebung

- Kein DNS-Verkehr beobachtet → bestätigt die Isolation von net-quarry.
- Keine externen IP-Adressen im Mitschnitt → gesamter Verkehr innerhalb von 192.168.50.0/24.

Fazit

Die Analyse von `silent_quarry.pcap` rekonstruiert einen gezielten, kompakten Angriff auf die Laborumgebung (192.168.50.0/24):

1. **Initialer Zugriff & RDP-Sitzung (00:23:42 UTC):** Der Angreifer (192.168.50.10) baute eine RDP-Verbindung zum Client (192.168.50.30) auf. Obwohl die Sitzung TLS-verschlüsselt war, legte die unverschlüsselte Verbindungsaushandlung den Benutzernamen "vogel" im Klartext-Cookie (`msthash=vogel`) offen. Das extrahierte TLS-Zertifikat bestätigte zudem den Hostnamen `DESKTOP-GKDAU52`.
2. **SSH-Kompromittierung & Exfiltration (00:24:35 UTC):** Unter Verwendung der kompromittierten "vogel"-Zugangsdaten meldete sich der Angreifer per SSH am Server (192.168.50.20) an. Diese erste, 233 Sekunden lange Sitzung trug den gesamten bössartigen Workflow (Authentifizierung, Lokalisierung, Abruf und anschließende Löschung der Zieldatei). Anhand von Paketgrößen, der Flussrichtung und zwei Aktivitätsschüben im I/O-Diagramm lässt sich eine Datenexfiltration von ca. 1 MB vom Server zum Angreifer belegen.
3. **Zweitverbindung (00:28:26 UTC):** Eine spätere, nur 6-sekündige SSH-Verbindung diente vermutlich lediglich einer kurzen Wiederverbindung und wies keine Anzeichen weiterer Datenextraktion auf.

Limitation der Netzanalyse: Während der Paketmitschnitt den Diebstahl der Zugangsdaten und die anschließende Datenexfiltration zweifelsfrei belegt, bleiben die initiale lokale Infektion (Ausführung von `main.py`) sowie die konkret ausgeführten SSH-Befehle im PCAP unsichtbar. Zur lückenlosen Aufklärung sollte diese Netzwerkanalyse durch Host- und Arbeitsspeicherforensik der betroffenen Endpunkte ergänzt werden.